

SYSTEM AND SERVICES ACQUISITION	SA-1	SA-1	SYSTEM AND SERVICES ACQUISITION POLICY AND PROCEDURES	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-1	SA-1a	SYSTEM AND SERVICES ACQUISITION POLICY AND PROCEDURES	Develops, documents, and disseminates to [Assignment: organization-defined personnel or roles]:
SYSTEM AND SERVICES ACQUISITION	SA-1	SA-1a.1	SYSTEM AND SERVICES ACQUISITION POLICY AND PROCEDURES	A system and services acquisition policy that addresses purpose, scope, roles, responsibilities, management commitment, coordination among organizational entities, and compliance; and
SYSTEM AND SERVICES ACQUISITION	SA-1	SA-1a.2	SYSTEM AND SERVICES ACQUISITION POLICY AND PROCEDURES	Procedures to facilitate the implementation of the system and services acquisition policy and associated system and services acquisition controls; and
SYSTEM AND SERVICES ACQUISITION	SA-1	SA-1b	SYSTEM AND SERVICES ACQUISITION POLICY AND PROCEDURES	Reviews and updates the current:
SYSTEM AND SERVICES ACQUISITION	SA-1	SA-1b.1	SYSTEM AND SERVICES ACQUISITION POLICY AND PROCEDURES	System and services acquisition policy [Assignment: organization-defined frequency]; and

SYSTEM AND SERVICES ACQUISITION	SA-1	SA-1b.2	SYSTEM AND SERVICES ACQUISITION POLICY AND PROCEDURES	System and services acquisition procedures [Assignment: organization-defined frequency].
SYSTEM AND SERVICES ACQUISITION	SA-2	SA-2	ALLOCATION OF RESOURCES	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-2	SA-2a	ALLOCATION OF RESOURCES	Determines information security requirements for the information system or information system service in mission/business process planning;
SYSTEM AND SERVICES ACQUISITION	SA-2	SA-2b	ALLOCATION OF RESOURCES	Determines, documents, and allocates the resources required to protect the information system or information system service as part of its capital planning and investment control process; and
SYSTEM AND SERVICES ACQUISITION	SA-2	SA-2c	ALLOCATION OF RESOURCES	Establishes a discrete line item for information security in organizational programming and budgeting documentation.
SYSTEM AND SERVICES ACQUISITION	SA-3	SA-3	SYSTEM DEVELOPMENT LIFE CYCLE	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-3	SA-3a	SYSTEM DEVELOPMENT LIFE CYCLE	Manages the information system using [Assignment: organization-defined system development life cycle] that incorporates information security considerations;
SYSTEM AND SERVICES ACQUISITION	SA-3	SA-3b	SYSTEM DEVELOPMENT LIFE CYCLE	Defines and documents information security roles and responsibilities throughout the system development life cycle;
SYSTEM AND SERVICES ACQUISITION	SA-3	SA-3c	SYSTEM DEVELOPMENT LIFE CYCLE	Identifies individuals having information security roles and responsibilities; and

SYSTEM AND SERVICES ACQUISITION	SA-3	SA-3d	SYSTEM DEVELOPMENT LIFE CYCLE	Integrates the organizational information security risk management process into system development life cycle activities.
SYSTEM AND SERVICES ACQUISITION	SA-4	SA-4	ACQUISITION PROCESS	The organization includes the following requirements, descriptions, and criteria, explicitly or by reference, in the acquisition contract for the information system, system component, or information system service in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, standards, guidelines, and organizational mission/business needs:
SYSTEM AND SERVICES ACQUISITION	SA-4	SA-4a	ACQUISITION PROCESS	Security functional requirements;
SYSTEM AND SERVICES ACQUISITION	SA-4	SA-4b	ACQUISITION PROCESS	Security strength requirements;
SYSTEM AND SERVICES ACQUISITION	SA-4	SA-4c	ACQUISITION PROCESS	Security assurance requirements;

SYSTEM AND SERVICES ACQUISITION	SA-4	SA-4d	ACQUISITION PROCESS	Security-related documentation requirements;
SYSTEM AND SERVICES ACQUISITION	SA-4	SA-4e	ACQUISITION PROCESS	Requirements for protecting security-related documentation;
SYSTEM AND SERVICES ACQUISITION	SA-4	SA-4f	ACQUISITION PROCESS	Description of the information system development environment and environment in which the system is intended to operate; and
SYSTEM AND SERVICES ACQUISITION	SA-4	SA-4g	ACQUISITION PROCESS	Acceptance criteria.
SYSTEM AND SERVICES ACQUISITION	SA-4 (1)	SA-4 (1)	FUNCTIONAL PROPERTIES OF SECURITY CONTROLS	The organization requires the developer of the information system, system component, or information system service to provide a description of the functional properties of the security controls to be employed.

SYSTEM AND SERVICES ACQUISITION	SA-4 (2)	SA-4 (2)	DESIGN / IMPLEMENTATION INFORMATION FOR SECURITY CONTROLS	The organization requires the developer of the information system, system component, or information system service to provide design and implementation information for the security controls to be employed that includes: [Selection (one or more): security-relevant external system interfaces; high-level design; low-level design; source code or hardware schematics; [Assignment: organization-defined design/implementation information]] at [Assignment: organization-defined level of detail].
SYSTEM AND SERVICES ACQUISITION	SA-4 (3)	SA-4 (3)	DEVELOPMENT METHODS / TECHNIQUES / PRACTICES	The organization requires the developer of the information system, system component, or information system service to demonstrate the use of a system development life cycle that includes [Assignment: organization-defined state-of-the-practice system/security engineering methods, software development methods, testing/evaluation/validation techniques, and quality control processes].
SYSTEM AND SERVICES ACQUISITION	SA-4 (4)	SA-4 (4)	ASSIGNMENT OF COMPONENTS TO SYSTEMS	[Withdrawn: Incorporated into CM-8 (9)].
SYSTEM AND SERVICES ACQUISITION	SA-4 (5)	SA-4 (5)	SYSTEM / COMPONENT / SERVICE CONFIGURATIONS	The organization requires the developer of the information system, system component, or information system service to:
SYSTEM AND SERVICES ACQUISITION	SA-4 (5)	SA-4 (5)(a)	SYSTEM / COMPONENT / SERVICE CONFIGURATIONS	Deliver the system, component, or service with [Assignment: organization-defined security configurations] implemented; and

SYSTEM AND SERVICES ACQUISITION	SA-4 (5)	SA-4 (5)(b)	SYSTEM / COMPONENT / SERVICE CONFIGURATIONS	Use the configurations as the default for any subsequent system, component, or service reinstallation or upgrade.
SYSTEM AND SERVICES ACQUISITION	SA-4 (6)	SA-4 (6)	USE OF INFORMATION ASSURANCE PRODUCTS	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-4 (6)	SA-4 (6)(a)	USE OF INFORMATION ASSURANCE PRODUCTS	Employs only government off-the-shelf (GOTS) or commercial off-the-shelf (COTS) information assurance (IA) and IA-enabled information technology products that compose an NSA-approved solution to protect classified information when the networks used to transmit the information are at a lower classification level than the information being transmitted; and
SYSTEM AND SERVICES ACQUISITION	SA-4 (6)	SA-4 (6)(b)	USE OF INFORMATION ASSURANCE PRODUCTS	Ensures that these products have been evaluated and/or validated by NSA or in accordance with NSA-approved procedures.
SYSTEM AND SERVICES ACQUISITION	SA-4 (7)	SA-4 (7)	NIAP-APPROVED PROTECTION PROFILES	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-4 (7)	SA-4 (7)(a)	NIAP-APPROVED PROTECTION PROFILES	Limits the use of commercially provided information assurance (IA) and IA-enabled information technology products to those products that have been successfully evaluated against a National Information Assurance partnership (NIAP)-approved Protection Profile for a specific technology type, if such a profile exists; and

SYSTEM AND SERVICES ACQUISITION	SA-4 (7)	SA-4 (7)(b)	NIAP-APPROVED PROTECTION PROFILES	Requires, if no NIAP-approved Protection Profile exists for a specific technology type but a commercially provided information technology product relies on cryptographic functionality to enforce its security policy, that the cryptographic module is FIPS-validated.
SYSTEM AND SERVICES ACQUISITION	SA-4 (8)	SA-4 (8)	CONTINUOUS MONITORING PLAN	The organization requires the developer of the information system, system component, or information system service to produce a plan for the continuous monitoring of security control effectiveness that contains [Assignment: organization-defined level of detail].
SYSTEM AND SERVICES ACQUISITION	SA-4 (9)	SA-4 (9)	FUNCTIONS / PORTS / PROTOCOLS / SERVICES IN USE	The organization requires the developer of the information system, system component, or information system service to identify early in the system development life cycle, the functions, ports, protocols, and services intended for organizational use.
SYSTEM AND SERVICES ACQUISITION	SA-4 (10)	SA-4 (10)	USE OF APPROVED PIV PRODUCTS	The organization employs only information technology products on the FIPS 201-approved products list for Personal Identity Verification (PIV) capability implemented within organizational information systems.
SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5	INFORMATION SYSTEM DOCUMENTATION	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5a	INFORMATION SYSTEM DOCUMENTATION	Obtains administrator documentation for the information system, system component, or information system service that describes:

SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5a.1	INFORMATION SYSTEM DOCUMENTATION	Secure configuration, installation, and operation of the system, component, or service;
SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5a.2	INFORMATION SYSTEM DOCUMENTATION	Effective use and maintenance of security functions/mechanisms; and
SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5a.3	INFORMATION SYSTEM DOCUMENTATION	Known vulnerabilities regarding configuration and use of administrative (i.e., privileged) functions;
SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5b	INFORMATION SYSTEM DOCUMENTATION	Obtains user documentation for the information system, system component, or information system service that describes:
SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5b.1	INFORMATION SYSTEM DOCUMENTATION	User-accessible security functions/mechanisms and how to effectively use those security functions/mechanisms;
SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5b.2	INFORMATION SYSTEM DOCUMENTATION	Methods for user interaction, which enables individuals to use the system, component, or service in a more secure manner; and
SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5b.3	INFORMATION SYSTEM DOCUMENTATION	User responsibilities in maintaining the security of the system, component, or service;

SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5c	INFORMATION SYSTEM DOCUMENTATION	Documents attempts to obtain information system, system component, or information system service documentation when such documentation is either unavailable or nonexistent and takes [Assignment: organization-defined actions] in response;
SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5d	INFORMATION SYSTEM DOCUMENTATION	Protects documentation as required, in accordance with the risk management strategy; and
SYSTEM AND SERVICES ACQUISITION	SA-5	SA-5e	INFORMATION SYSTEM DOCUMENTATION	Distributes documentation to [Assignment: organization-defined personnel or roles].
SYSTEM AND SERVICES ACQUISITION	SA-5 (1)	SA-5 (1)	FUNCTIONAL PROPERTIES OF SECURITY CONTROLS	[Withdrawn: Incorporated into SA-4 (1)].
SYSTEM AND SERVICES ACQUISITION	SA-5 (2)	SA-5 (2)	SECURITY-RELEVANT EXTERNAL SYSTEM INTERFACES	[Withdrawn: Incorporated into SA-4 (2)].
SYSTEM AND SERVICES ACQUISITION	SA-5 (3)	SA-5 (3)	HIGH-LEVEL DESIGN	[Withdrawn: Incorporated into SA-4 (2)].
SYSTEM AND SERVICES ACQUISITION	SA-5 (4)	SA-5 (4)	LOW-LEVEL DESIGN	[Withdrawn: Incorporated into SA-4 (2)].
SYSTEM AND SERVICES ACQUISITION	SA-5 (5)	SA-5 (5)	SOURCE CODE	[Withdrawn: Incorporated into SA-4 (2)].
SYSTEM AND SERVICES ACQUISITION	SA-6	SA-6	SOFTWARE USAGE RESTRICTIONS	[Withdrawn: Incorporated into CM-10 and SI-7].

SYSTEM AND SERVICES ACQUISITION	SA-7	SA-7	USER-INSTALLED SOFTWARE	[Withdrawn: Incorporated into CM-11 and SI-7].
SYSTEM AND SERVICES ACQUISITION	SA-8	SA-8	SECURITY ENGINEERING PRINCIPLES	The organization applies information system security engineering principles in the specification, design, development, implementation, and modification of the information system.
SYSTEM AND SERVICES ACQUISITION	SA-9	SA-9	EXTERNAL INFORMATION SYSTEM SERVICES	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-9	SA-9a	EXTERNAL INFORMATION SYSTEM SERVICES	Requires that providers of external information system services comply with organizational information security requirements and employ [Assignment: organization-defined security controls] in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, standards, and guidance;
SYSTEM AND SERVICES ACQUISITION	SA-9	SA-9b	EXTERNAL INFORMATION SYSTEM SERVICES	Defines and documents government oversight and user roles and responsibilities with regard to external information system services; and
SYSTEM AND SERVICES ACQUISITION	SA-9	SA-9c	EXTERNAL INFORMATION SYSTEM SERVICES	Employs [Assignment: organization-defined processes, methods, and techniques] to monitor security control compliance by external service providers on an ongoing basis.

SYSTEM AND SERVICES ACQUISITION	SA-9 (1)	SA-9 (1)	RISK ASSESSMENTS / ORGANIZATIONAL APPROVALS	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-9 (1)	SA-9 (1)(a)	RISK ASSESSMENTS / ORGANIZATIONAL APPROVALS	Conducts an organizational assessment of risk prior to the acquisition or outsourcing of dedicated information security services; and
SYSTEM AND SERVICES ACQUISITION	SA-9 (1)	SA-9 (1)(b)	RISK ASSESSMENTS / ORGANIZATIONAL APPROVALS	Ensures that the acquisition or outsourcing of dedicated information security services is approved by [Assignment: organization-defined personnel or roles].
SYSTEM AND SERVICES ACQUISITION	SA-9 (2)	SA-9 (2)	IDENTIFICATION OF FUNCTIONS / PORTS / PROTOCOLS / SERVICES	The organization requires providers of [Assignment: organization-defined external information system services] to identify the functions, ports, protocols, and other services required for the use of such services.
SYSTEM AND SERVICES ACQUISITION	SA-9 (3)	SA-9 (3)	ESTABLISH / MAINTAIN TRUST RELATIONSHIP WITH PROVIDERS	The organization establishes, documents, and maintains trust relationships with external service providers based on [Assignment: organization-defined security requirements, properties, factors, or conditions defining acceptable trust relationships].

SYSTEM AND SERVICES ACQUISITION	SA-9 (4)	SA-9 (4)	CONSISTENT INTERESTS OF CONSUMERS AND PROVIDERS	The organization employs [Assignment: organization-defined security safeguards] to ensure that the interests of [Assignment: organization-defined external service providers] are consistent with and reflect organizational interests.
SYSTEM AND SERVICES ACQUISITION	SA-9 (5)	SA-9 (5)	PROCESSING, STORAGE, AND SERVICE LOCATION	The organization restricts the location of [Selection (one or more): information processing; information/data; information system services] to [Assignment: organization-defined locations] based on [Assignment: organization-defined requirements or conditions].
SYSTEM AND SERVICES ACQUISITION	SA-10	SA-10	DEVELOPER CONFIGURATION MANAGEMENT	The organization requires the developer of the information system, system component, or information system service to:
SYSTEM AND SERVICES ACQUISITION	SA-10	SA-10a	DEVELOPER CONFIGURATION MANAGEMENT	Perform configuration management during system, component, or service [Selection (one or more): design; development; implementation; operation];
SYSTEM AND SERVICES ACQUISITION	SA-10	SA-10b	DEVELOPER CONFIGURATION MANAGEMENT	Document, manage, and control the integrity of changes to [Assignment: organization-defined configuration items under configuration management];
SYSTEM AND SERVICES ACQUISITION	SA-10	SA-10c	DEVELOPER CONFIGURATION MANAGEMENT	Implement only organization-approved changes to the system, component, or service;
SYSTEM AND SERVICES ACQUISITION	SA-10	SA-10d	DEVELOPER CONFIGURATION MANAGEMENT	Document approved changes to the system, component, or service and the potential security impacts of such changes; and

SYSTEM AND SERVICES ACQUISITION	SA-10	SA-10e	DEVELOPER CONFIGURATION MANAGEMENT	Track security flaws and flaw resolution within the system, component, or service and report findings to [Assignment: organization-defined personnel].
SYSTEM AND SERVICES ACQUISITION	SA-10 (1)	SA-10 (1)	SOFTWARE / FIRMWARE INTEGRITY VERIFICATION	The organization requires the developer of the information system, system component, or information system service to enable integrity verification of software and firmware components.
SYSTEM AND SERVICES ACQUISITION	SA-10 (2)	SA-10 (2)	ALTERNATIVE CONFIGURATION MANAGEMENT PROCESSES	The organization provides an alternate configuration management process using organizational personnel in the absence of a dedicated developer configuration management team.
SYSTEM AND SERVICES ACQUISITION	SA-10 (3)	SA-10 (3)	HARDWARE INTEGRITY VERIFICATION	The organization requires the developer of the information system, system component, or information system service to enable integrity verification of hardware components.
SYSTEM AND SERVICES ACQUISITION	SA-10 (4)	SA-10 (4)	TRUSTED GENERATION	The organization requires the developer of the information system, system component, or information system service to employ tools for comparing newly generated versions of security-relevant hardware descriptions and software/firmware source and object code with previous versions.

SYSTEM AND SERVICES ACQUISITION	SA-10 (5)	SA-10 (5)	MAPPING INTEGRITY FOR VERSION CONTROL	The organization requires the developer of the information system, system component, or information system service to maintain the integrity of the mapping between the master build data (hardware drawings and software/firmware code) describing the current version of security-relevant hardware, software, and firmware and the on-site master copy of the data for the current version.
SYSTEM AND SERVICES ACQUISITION	SA-10 (6)	SA-10 (6)	TRUSTED DISTRIBUTION	The organization requires the developer of the information system, system component, or information system service to execute procedures for ensuring that security-relevant hardware, software, and firmware updates distributed to the organization are exactly as specified by the master copies.
SYSTEM AND SERVICES ACQUISITION	SA-11	SA-11	DEVELOPER SECURITY TESTING AND EVALUATION	The organization requires the developer of the information system, system component, or information system service to:
SYSTEM AND SERVICES ACQUISITION	SA-11	SA-11a	DEVELOPER SECURITY TESTING AND EVALUATION	Create and implement a security assessment plan;
SYSTEM AND SERVICES ACQUISITION	SA-11	SA-11b	DEVELOPER SECURITY TESTING AND EVALUATION	Perform [Selection (one or more): unit; integration; system; regression] testing/evaluation at [Assignment: organization-defined depth and coverage];
SYSTEM AND SERVICES ACQUISITION	SA-11	SA-11c	DEVELOPER SECURITY TESTING AND EVALUATION	Produce evidence of the execution of the security assessment plan and the results of the security testing/evaluation;
SYSTEM AND SERVICES ACQUISITION	SA-11	SA-11d	DEVELOPER SECURITY TESTING AND EVALUATION	Implement a verifiable flaw remediation process; and

SYSTEM AND SERVICES ACQUISITION	SA-11	SA-11e	DEVELOPER SECURITY TESTING AND EVALUATION	Correct flaws identified during security testing/evaluation.
SYSTEM AND SERVICES ACQUISITION	SA-11 (1)	SA-11 (1)	STATIC CODE ANALYSIS	The organization requires the developer of the information system, system component, or information system service to employ static code analysis tools to identify common flaws and document the results of the analysis.
SYSTEM AND SERVICES ACQUISITION	SA-11 (2)	SA-11 (2)	THREAT AND VULNERABILITY ANALYSES	The organization requires the developer of the information system, system component, or information system service to perform threat and vulnerability analyses and subsequent testing/evaluation of the as-built system, component, or service.
SYSTEM AND SERVICES ACQUISITION	SA-11 (3)	SA-11 (3)	INDEPENDENT VERIFICATION OF ASSESSMENT PLANS / EVIDENCE	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-11 (3)	SA-11 (3)(a)	INDEPENDENT VERIFICATION OF ASSESSMENT PLANS / EVIDENCE	Requires an independent agent satisfying [Assignment: organization-defined independence criteria] to verify the correct implementation of the developer security assessment plan and the evidence produced during security testing/evaluation; and
SYSTEM AND SERVICES ACQUISITION	SA-11 (3)	SA-11 (3)(b)	INDEPENDENT VERIFICATION OF ASSESSMENT PLANS / EVIDENCE	Ensures that the independent agent is either provided with sufficient information to complete the verification process or granted the authority to obtain such information.

SYSTEM AND SERVICES ACQUISITION	SA-11 (4)	SA-11 (4)	MANUAL CODE REVIEWS	The organization requires the developer of the information system, system component, or information system service to perform a manual code review of [Assignment: organization-defined specific code] using [Assignment: organization-defined processes, procedures, and/or techniques].
SYSTEM AND SERVICES ACQUISITION	SA-11 (5)	SA-11 (5)	PENETRATION TESTING	The organization requires the developer of the information system, system component, or information system service to perform penetration testing at [Assignment: organization-defined breadth/depth] and with [Assignment: organization-defined constraints].
SYSTEM AND SERVICES ACQUISITION	SA-11 (6)	SA-11 (6)	ATTACK SURFACE REVIEWS	The organization requires the developer of the information system, system component, or information system service to perform attack surface reviews.
SYSTEM AND SERVICES ACQUISITION	SA-11 (7)	SA-11 (7)	VERIFY SCOPE OF TESTING / EVALUATION	The organization requires the developer of the information system, system component, or information system service to verify that the scope of security testing/evaluation provides complete coverage of required security controls at [Assignment: organization-defined depth of testing/evaluation].
SYSTEM AND SERVICES ACQUISITION	SA-11 (8)	SA-11 (8)	DYNAMIC CODE ANALYSIS	The organization requires the developer of the information system, system component, or information system service to employ dynamic code analysis tools to identify common flaws and document the results of the analysis.

SYSTEM AND SERVICES ACQUISITION	SA-12	SA-12	SUPPLY CHAIN PROTECTION	The organization protects against supply chain threats to the information system, system component, or information system service by employing [Assignment: organization-defined security safeguards] as part of a comprehensive, defense-in-breadth information security strategy.
SYSTEM AND SERVICES ACQUISITION	SA-12 (1)	SA-12 (1)	ACQUISITION STRATEGIES / TOOLS / METHODS	The organization employs [Assignment: organization-defined tailored acquisition strategies, contract tools, and procurement methods] for the purchase of the information system, system component, or information system service from suppliers.
SYSTEM AND SERVICES ACQUISITION	SA-12 (2)	SA-12 (2)	SUPPLIER REVIEWS	The organization conducts a supplier review prior to entering into a contractual agreement to acquire the information system, system component, or information system service.
SYSTEM AND SERVICES ACQUISITION	SA-12 (3)	SA-12 (3)	TRUSTED SHIPPING AND WAREHOUSING	[Withdrawn: Incorporated into SA-12 (1)].
SYSTEM AND SERVICES ACQUISITION	SA-12 (4)	SA-12 (4)	DIVERSITY OF SUPPLIERS	[Withdrawn: Incorporated into SA-12 (13)].
SYSTEM AND SERVICES ACQUISITION	SA-12 (5)	SA-12 (5)	LIMITATION OF HARM	The organization employs [Assignment: organization-defined security safeguards] to limit harm from potential adversaries identifying and targeting the organizational supply chain.
SYSTEM AND SERVICES ACQUISITION	SA-12 (6)	SA-12 (6)	MINIMIZING PROCUREMENT TIME	[Withdrawn: Incorporated into SA-12 (1)].

SYSTEM AND SERVICES ACQUISITION	SA-12 (7)	SA-12 (7)	ASSESSMENTS PRIOR TO SELECTION / ACCEPTANCE / UPDATE	The organization conducts an assessment of the information system, system component, or information system service prior to selection, acceptance, or update.
SYSTEM AND SERVICES ACQUISITION	SA-12 (8)	SA-12 (8)	USE OF ALL-SOURCE INTELLIGENCE	The organization uses all-source intelligence analysis of suppliers and potential suppliers of the information system, system component, or information system service.
SYSTEM AND SERVICES ACQUISITION	SA-12 (9)	SA-12 (9)	OPERATIONS SECURITY	The organization employs [Assignment: organization-defined Operations Security (OPSEC) safeguards] in accordance with classification guides to protect supply chain-related information for the information system, system component, or information system service.
SYSTEM AND SERVICES ACQUISITION	SA-12 (10)	SA-12 (10)	VALIDATE AS GENUINE AND NOT ALTERED	The organization employs [Assignment: organization-defined security safeguards] to validate that the information system or system component received is genuine and has not been altered.
SYSTEM AND SERVICES ACQUISITION	SA-12 (11)	SA-12 (11)	PENETRATION TESTING / ANALYSIS OF ELEMENTS, PROCESSES, AND ACTORS	The organization employs [Selection (one or more): organizational analysis, independent third-party analysis, organizational penetration testing, independent third-party penetration testing] of [Assignment: organization-defined supply chain elements, processes, and actors] associated with the information system, system component, or information system service.

SYSTEM AND SERVICES ACQUISITION	SA-12 (12)	SA-12 (12)	INTER-ORGANIZATIONAL AGREEMENTS	The organization establishes inter-organizational agreements and procedures with entities involved in the supply chain for the information system, system component, or information system service.
SYSTEM AND SERVICES ACQUISITION	SA-12 (13)	SA-12 (13)	CRITICAL INFORMATION SYSTEM COMPONENTS	The organization employs [Assignment: organization-defined security safeguards] to ensure an adequate supply of [Assignment: organization-defined critical information system components].
SYSTEM AND SERVICES ACQUISITION	SA-12 (14)	SA-12 (14)	IDENTITY AND TRACEABILITY	The organization establishes and retains unique identification of [Assignment: organization-defined supply chain elements, processes, and actors] for the information system, system component, or information system service.
SYSTEM AND SERVICES ACQUISITION	SA-12 (15)	SA-12 (15)	PROCESSES TO ADDRESS WEAKNESSES OR DEFICIENCIES	The organization establishes a process to address weaknesses or deficiencies in supply chain elements identified during independent or organizational assessments of such elements.
SYSTEM AND SERVICES ACQUISITION	SA-13	SA-13	TRUSTWORTHINESS	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-13	SA-13a	TRUSTWORTHINESS	Describes the trustworthiness required in the [Assignment: organization-defined information system, information system component, or information system service] supporting its critical missions/business functions; and
SYSTEM AND SERVICES ACQUISITION	SA-13	SA-13b	TRUSTWORTHINESS	Implements [Assignment: organization-defined assurance overlay] to achieve such trustworthiness.

SYSTEM AND SERVICES ACQUISITION	SA-14	SA-14	CRITICALITY ANALYSIS	The organization identifies critical information system components and functions by performing a criticality analysis for [Assignment: organization-defined information systems, information system components, or information system services] at [Assignment: organization-defined decision points in the system development life cycle].
SYSTEM AND SERVICES ACQUISITION	SA-14 (1)	SA-14 (1)	CRITICAL COMPONENTS WITH NO VIABLE ALTERNATIVE SOURCING	[Withdrawn: Incorporated into SA-20].
SYSTEM AND SERVICES ACQUISITION	SA-15	SA-15	DEVELOPMENT PROCESS, STANDARDS, AND TOOLS	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-15	SA-15a	DEVELOPMENT PROCESS, STANDARDS, AND TOOLS	Requires the developer of the information system, system component, or information system service to follow a documented development process that:
SYSTEM AND SERVICES ACQUISITION	SA-15	SA-15a.1	DEVELOPMENT PROCESS, STANDARDS, AND TOOLS	Explicitly addresses security requirements;
SYSTEM AND SERVICES ACQUISITION	SA-15	SA-15a.2	DEVELOPMENT PROCESS, STANDARDS, AND TOOLS	Identifies the standards and tools used in the development process;
SYSTEM AND SERVICES ACQUISITION	SA-15	SA-15a.3	DEVELOPMENT PROCESS, STANDARDS, AND TOOLS	Documents the specific tool options and tool configurations used in the development process; and

SYSTEM AND SERVICES ACQUISITION	SA-15	SA-15a.4	DEVELOPMENT PROCESS, STANDARDS, AND TOOLS	Documents, manages, and ensures the integrity of changes to the process and/or tools used in development; and
SYSTEM AND SERVICES ACQUISITION	SA-15	SA-15b	DEVELOPMENT PROCESS, STANDARDS, AND TOOLS	Reviews the development process, standards, tools, and tool options/configurations [Assignment: organization-defined frequency] to determine if the process, standards, tools, and tool options/configurations selected and employed can satisfy [Assignment: organization-defined security requirements].
SYSTEM AND SERVICES ACQUISITION	SA-15 (1)	SA-15 (1)	QUALITY METRICS	The organization requires the developer of the information system, system component, or information system service to:
SYSTEM AND SERVICES ACQUISITION	SA-15 (1)	SA-15 (1)(a)	QUALITY METRICS	Define quality metrics at the beginning of the development process; and
SYSTEM AND SERVICES ACQUISITION	SA-15 (1)	SA-15 (1)(b)	QUALITY METRICS	Provide evidence of meeting the quality metrics [Selection (one or more): [Assignment: organization-defined frequency]; [Assignment: organization-defined program review milestones]; upon delivery].
SYSTEM AND SERVICES ACQUISITION	SA-15 (2)	SA-15 (2)	SECURITY TRACKING TOOLS	The organization requires the developer of the information system, system component, or information system service to select and employ a security tracking tool for use during the development process.
SYSTEM AND SERVICES ACQUISITION	SA-15 (3)	SA-15 (3)	CRITICALITY ANALYSIS	The organization requires the developer of the information system, system component, or information system service to perform a criticality analysis at [Assignment: organization-defined breadth/depth] and at [Assignment: organization-defined decision points in the system development life cycle].

SYSTEM AND SERVICES ACQUISITION	SA-15 (4)	SA-15 (4)	THREAT MODELING / VULNERABILITY ANALYSIS	The organization requires that developers perform threat modeling and a vulnerability analysis for the information system at [Assignment: organization-defined breadth/depth] that:
SYSTEM AND SERVICES ACQUISITION	SA-15 (4)	SA-15 (4)(a)	THREAT MODELING / VULNERABILITY ANALYSIS	Uses [Assignment: organization-defined information concerning impact, environment of operations, known or assumed threats, and acceptable risk levels];
SYSTEM AND SERVICES ACQUISITION	SA-15 (4)	SA-15 (4)(b)	THREAT MODELING / VULNERABILITY ANALYSIS	Employs [Assignment: organization-defined tools and methods]; and
SYSTEM AND SERVICES ACQUISITION	SA-15 (4)	SA-15 (4)(c)	THREAT MODELING / VULNERABILITY ANALYSIS	Produces evidence that meets [Assignment: organization-defined acceptance criteria].
SYSTEM AND SERVICES ACQUISITION	SA-15 (5)	SA-15 (5)	ATTACK SURFACE REDUCTION	The organization requires the developer of the information system, system component, or information system service to reduce attack surfaces to [Assignment: organization-defined thresholds].
SYSTEM AND SERVICES ACQUISITION	SA-15 (6)	SA-15 (6)	CONTINUOUS IMPROVEMENT	The organization requires the developer of the information system, system component, or information system service to implement an explicit process to continuously improve the development process.
SYSTEM AND SERVICES ACQUISITION	SA-15 (7)	SA-15 (7)	AUTOMATED VULNERABILITY ANALYSIS	The organization requires the developer of the information system, system component, or information system service to:
SYSTEM AND SERVICES ACQUISITION	SA-15 (7)	SA-15 (7)(a)	AUTOMATED VULNERABILITY ANALYSIS	Perform an automated vulnerability analysis using [Assignment: organization-defined tools];
SYSTEM AND SERVICES ACQUISITION	SA-15 (7)	SA-15 (7)(b)	AUTOMATED VULNERABILITY ANALYSIS	Determine the exploitation potential for discovered vulnerabilities;

SYSTEM AND SERVICES ACQUISITION	SA-15 (7)	SA-15 (7)(c)	AUTOMATED VULNERABILITY ANALYSIS	Determine potential risk mitigations for delivered vulnerabilities; and
SYSTEM AND SERVICES ACQUISITION	SA-15 (7)	SA-15 (7)(d)	AUTOMATED VULNERABILITY ANALYSIS	Deliver the outputs of the tools and results of the analysis to [Assignment: organization-defined personnel or roles].
SYSTEM AND SERVICES ACQUISITION	SA-15 (8)	SA-15 (8)	REUSE OF THREAT / VULNERABILITY INFORMATION	The organization requires the developer of the information system, system component, or information system service to use threat modeling and vulnerability analyses from similar systems, components, or services to inform the current development process.
SYSTEM AND SERVICES ACQUISITION	SA-15 (9)	SA-15 (9)	USE OF LIVE DATA	The organization approves, documents, and controls the use of live data in development and test environments for the information system, system component, or information system service.
SYSTEM AND SERVICES ACQUISITION	SA-15 (10)	SA-15 (10)	INCIDENT RESPONSE PLAN	The organization requires the developer of the information system, system component, or information system service to provide an incident response plan.
SYSTEM AND SERVICES ACQUISITION	SA-15 (11)	SA-15 (11)	ARCHIVE INFORMATION SYSTEM / COMPONENT	The organization requires the developer of the information system or system component to archive the system or component to be released or delivered together with the corresponding evidence supporting the final security review.
SYSTEM AND SERVICES ACQUISITION	SA-16	SA-16	DEVELOPER-PROVIDED TRAINING	The organization requires the developer of the information system, system component, or information system service to provide [Assignment: organization-defined training] on the correct use and operation of the implemented security functions, controls, and/or mechanisms.

SYSTEM AND SERVICES ACQUISITION	SA-17	SA-17	DEVELOPER SECURITY ARCHITECTURE AND DESIGN	The organization requires the developer of the information system, system component, or information system service to produce a design specification and security architecture that:
SYSTEM AND SERVICES ACQUISITION	SA-17	SA-17a	DEVELOPER SECURITY ARCHITECTURE AND DESIGN	Is consistent with and supportive of the organization's security architecture which is established within and is an integrated part of the organization's enterprise architecture;
SYSTEM AND SERVICES ACQUISITION	SA-17	SA-17b	DEVELOPER SECURITY ARCHITECTURE AND DESIGN	Accurately and completely describes the required security functionality, and the allocation of security controls among physical and logical components; and
SYSTEM AND SERVICES ACQUISITION	SA-17	SA-17c	DEVELOPER SECURITY ARCHITECTURE AND DESIGN	Expresses how individual security functions, mechanisms, and services work together to provide required security capabilities and a unified approach to protection.
SYSTEM AND SERVICES ACQUISITION	SA-17 (1)	SA-17 (1)	FORMAL POLICY MODEL	The organization requires the developer of the information system, system component, or information system service to:
SYSTEM AND SERVICES ACQUISITION	SA-17 (1)	SA-17 (1)(a)	FORMAL POLICY MODEL	Produce, as an integral part of the development process, a formal policy model describing the [Assignment: organization-defined elements of organizational security policy] to be enforced; and
SYSTEM AND SERVICES ACQUISITION	SA-17 (1)	SA-17 (1)(b)	FORMAL POLICY MODEL	Prove that the formal policy model is internally consistent and sufficient to enforce the defined elements of the organizational security policy when implemented.
SYSTEM AND SERVICES ACQUISITION	SA-17 (2)	SA-17 (2)	SECURITY-RELEVANT COMPONENTS	The organization requires the developer of the information system, system component, or information system service to:

SYSTEM AND SERVICES ACQUISITION	SA-17 (2)	SA-17 (2)(a)	SECURITY-RELEVANT COMPONENTS	Define security-relevant hardware, software, and firmware; and
SYSTEM AND SERVICES ACQUISITION	SA-17 (2)	SA-17 (2)(b)	SECURITY-RELEVANT COMPONENTS	Provide a rationale that the definition for security-relevant hardware, software, and firmware is complete.
SYSTEM AND SERVICES ACQUISITION	SA-17 (3)	SA-17 (3)	FORMAL CORRESPONDENCE	The organization requires the developer of the information system, system component, or information system service to:
SYSTEM AND SERVICES ACQUISITION	SA-17 (3)	SA-17 (3)(a)	FORMAL CORRESPONDENCE	Produce, as an integral part of the development process, a formal top-level specification that specifies the interfaces to security-relevant hardware, software, and firmware in terms of exceptions, error messages, and effects;
SYSTEM AND SERVICES ACQUISITION	SA-17 (3)	SA-17 (3)(b)	FORMAL CORRESPONDENCE	Show via proof to the extent feasible with additional informal demonstration as necessary, that the formal top-level specification is consistent with the formal policy model;
SYSTEM AND SERVICES ACQUISITION	SA-17 (3)	SA-17 (3)(c)	FORMAL CORRESPONDENCE	Show via informal demonstration, that the formal top-level specification completely covers the interfaces to security-relevant hardware, software, and firmware;
SYSTEM AND SERVICES ACQUISITION	SA-17 (3)	SA-17 (3)(d)	FORMAL CORRESPONDENCE	Show that the formal top-level specification is an accurate description of the implemented security-relevant hardware, software, and firmware; and
SYSTEM AND SERVICES ACQUISITION	SA-17 (3)	SA-17 (3)(e)	FORMAL CORRESPONDENCE	Describe the security-relevant hardware, software, and firmware mechanisms not addressed in the formal top-level specification but strictly internal to the security-relevant hardware, software, and firmware.

SYSTEM AND SERVICES ACQUISITION	SA-17 (4)	SA-17 (4)	INFORMAL CORRESPONDENCE	The organization requires the developer of the information system, system component, or information system service to:
SYSTEM AND SERVICES ACQUISITION	SA-17 (4)	SA-17 (4)(a)	INFORMAL CORRESPONDENCE	Produce, as an integral part of the development process, an informal descriptive top-level specification that specifies the interfaces to security-relevant hardware, software, and firmware in terms of exceptions, error messages, and effects;
SYSTEM AND SERVICES ACQUISITION	SA-17 (4)	SA-17 (4)(b)	INFORMAL CORRESPONDENCE	Show via [Selection: informal demonstration, convincing argument with formal methods as feasible] that the descriptive top-level specification is consistent with the formal policy model;
SYSTEM AND SERVICES ACQUISITION	SA-17 (4)	SA-17 (4)(c)	INFORMAL CORRESPONDENCE	Show via informal demonstration, that the descriptive top-level specification completely covers the interfaces to security-relevant hardware, software, and firmware;
SYSTEM AND SERVICES ACQUISITION	SA-17 (4)	SA-17 (4)(d)	INFORMAL CORRESPONDENCE	Show that the descriptive top-level specification is an accurate description of the interfaces to security-relevant hardware, software, and firmware; and
SYSTEM AND SERVICES ACQUISITION	SA-17 (4)	SA-17 (4)(e)	INFORMAL CORRESPONDENCE	Describe the security-relevant hardware, software, and firmware mechanisms not addressed in the descriptive top-level specification but strictly internal to the security-relevant hardware, software, and firmware.
SYSTEM AND SERVICES ACQUISITION	SA-17 (5)	SA-17 (5)	CONCEPTUALLY SIMPLE DESIGN	The organization requires the developer of the information system, system component, or information system service to:

SYSTEM AND SERVICES ACQUISITION	SA-17 (5)	SA-17 (5)(a)	CONCEPTUALLY SIMPLE DESIGN	Design and structure the security-relevant hardware, software, and firmware to use a complete, conceptually simple protection mechanism with precisely defined semantics; and
SYSTEM AND SERVICES ACQUISITION	SA-17 (5)	SA-17 (5)(b)	CONCEPTUALLY SIMPLE DESIGN	Internally structure the security-relevant hardware, software, and firmware with specific regard for this mechanism.
SYSTEM AND SERVICES ACQUISITION	SA-17 (6)	SA-17 (6)	STRUCTURE FOR TESTING	The organization requires the developer of the information system, system component, or information system service to structure security-relevant hardware, software, and firmware to facilitate testing.
SYSTEM AND SERVICES ACQUISITION	SA-17 (7)	SA-17 (7)	STRUCTURE FOR LEAST PRIVILEGE	The organization requires the developer of the information system, system component, or information system service to structure security-relevant hardware, software, and firmware to facilitate controlling access with least privilege.
SYSTEM AND SERVICES ACQUISITION	SA-18	SA-18	TAMPER RESISTANCE AND DETECTION	The organization implements a tamper protection program for the information system, system component, or information system service.
SYSTEM AND SERVICES ACQUISITION	SA-18 (1)	SA-18 (1)	MULTIPLE PHASES OF SDLC	The organization employs anti-tamper technologies and techniques during multiple phases in the system development life cycle including design, development, integration, operations, and maintenance.

SYSTEM AND SERVICES ACQUISITION	SA-18 (2)	SA-18 (2)	INSPECTION OF INFORMATION SYSTEMS, COMPONENTS, OR DEVICES	The organization inspects [Assignment: organization-defined information systems, system components, or devices] [Selection (one or more): at random; at [Assignment: organization-defined frequency], upon [Assignment: organization-defined indications of need for inspection]] to detect tampering.
SYSTEM AND SERVICES ACQUISITION	SA-19	SA-19	COMPONENT AUTHENTICITY	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-19	SA-19a	COMPONENT AUTHENTICITY	Develops and implements anti-counterfeit policy and procedures that include the means to detect and prevent counterfeit components from entering the information system; and
SYSTEM AND SERVICES ACQUISITION	SA-19	SA-19b	COMPONENT AUTHENTICITY	Reports counterfeit information system components to [Selection (one or more): source of counterfeit component; [Assignment: organization-defined external reporting organizations]; [Assignment: organization-defined personnel or roles]].
SYSTEM AND SERVICES ACQUISITION	SA-19 (1)	SA-19 (1)	ANTI-COUNTERFEIT TRAINING	The organization trains [Assignment: organization-defined personnel or roles] to detect counterfeit information system components (including hardware, software, and firmware).
SYSTEM AND SERVICES ACQUISITION	SA-19 (2)	SA-19 (2)	CONFIGURATION CONTROL FOR COMPONENT SERVICE / REPAIR	The organization maintains configuration control over [Assignment: organization-defined information system components] awaiting service/repair and serviced/repared components awaiting return to service.
SYSTEM AND SERVICES ACQUISITION	SA-19 (3)	SA-19 (3)	COMPONENT DISPOSAL	The organization disposes of information system components using [Assignment: organization-defined techniques and methods].

SYSTEM AND SERVICES ACQUISITION	SA-19 (4)	SA-19 (4)	ANTI-COUNTERFEIT SCANNING	The organization scans for counterfeit information system components [Assignment: organization-defined frequency].
SYSTEM AND SERVICES ACQUISITION	SA-20	SA-20	CUSTOMIZED DEVELOPMENT OF CRITICAL COMPONENTS	The organization re-implements or custom develops [Assignment: organization-defined critical information system components].
SYSTEM AND SERVICES ACQUISITION	SA-21	SA-21	DEVELOPER SCREENING	The organization requires that the developer of [Assignment: organization-defined information system, system component, or information system service]:
SYSTEM AND SERVICES ACQUISITION	SA-21	SA-21a	DEVELOPER SCREENING	Have appropriate access authorizations as determined by assigned [Assignment: organization-defined official government duties]; and
SYSTEM AND SERVICES ACQUISITION	SA-21	SA-21b	DEVELOPER SCREENING	Satisfy [Assignment: organization-defined additional personnel screening criteria].
SYSTEM AND SERVICES ACQUISITION	SA-21 (1)	SA-21 (1)	VALIDATION OF SCREENING	The organization requires the developer of the information system, system component, or information system service take [Assignment: organization-defined actions] to ensure that the required access authorizations and screening criteria are satisfied.
SYSTEM AND SERVICES ACQUISITION	SA-22	SA-22	UNSUPPORTED SYSTEM COMPONENTS	The organization:
SYSTEM AND SERVICES ACQUISITION	SA-22	SA-22a	UNSUPPORTED SYSTEM COMPONENTS	Replaces information system components when support for the components is no longer available from the developer, vendor, or manufacturer; and

SYSTEM AND SERVICES ACQUISITION	SA-22	SA-22b	UNSUPPORTED SYSTEM COMPONENTS	Provides justification and documents approval for the continued use of unsupported system components required to satisfy mission/business needs.
SYSTEM AND SERVICES ACQUISITION	SA-22 (1)	SA-22 (1)	ALTERNATIVE SOURCES FOR CONTINUED SUPPORT	The organization provides [Selection (one or more): in-house support; [Assignment: organization-defined support from external providers]] for unsupported information system components.